05-5-pod-identity-policy

accounts-api security assessment · generated from the repository, not hand-edited

```
{
  "_comment": [
    "accounts-api pod identity role — the policy I would actually ship. Section 4c.",
    "Replaces a NotAction/Allow blanket (iam/pod-identity-policy-original.json).",
    "Threat T2. Rationale and the one-line diff statement: docs/04-findings.md."
  ],
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadCurrentDbCredentialOnly",
      "Effect": "Allow",
      "Action": [
        "secretsmanager:GetSecretValue",
        "secretsmanager:DescribeSecret"
      ],
      "Resource": "arn:aws:secretsmanager:ap-south-1:123456789012:secret:prod/accounts-api/db-*",
      "Condition": {
        "ForAnyValue:StringEquals": {
          "secretsmanager:VersionStage": "AWSCURRENT"
        }
      }
    },
    {
      "Sid": "DecryptThatSecretViaSecretsManagerOnly",
      "Effect": "Allow",
      "Action": "kms:Decrypt",
      "Resource": "arn:aws:kms:ap-south-1:123456789012:key/8f1c2b4e-2a77-4d31-9f0e-6d1a5c3b7e42",
      "Condition": {
        "StringEquals": {
          "kms:ViaService": "secretsmanager.ap-south-1.amazonaws.com",
          "kms:EncryptionContext:SecretARN": "arn:aws:secretsmanager:ap-south-
1:123456789012:secret:prod/accounts-api/db"
        }
      }
    },
    {
      "Sid": "ConsumeAccountEventsAndWriteAuditRecords",
      "Effect": "Allow",
      "Action": [
        "kafka-cluster:Connect",
        "kafka-cluster:DescribeTopic",
        "kafka-cluster:DescribeGroup",
        "kafka-cluster:AlterGroup",
        "kafka-cluster:ReadData"
      ],
      "Resource": [
        "arn:aws:kafka:ap-south-1:123456789012:cluster/retail-prod/*",
        "arn:aws:kafka:ap-south-1:123456789012:topic/retail-prod/*/accounts.events",
        "arn:aws:kafka:ap-south-1:123456789012:group/retail-prod/*/accounts-api"
      ]
    },
    {
      "Sid": "WriteAuditTopicOnly",
      "Effect": "Allow",
      "Action": "kafka-cluster:WriteData",
      "Resource": "arn:aws:kafka:ap-south-1:123456789012:topic/retail-prod/*/accounts.audit"
    },
```

```
    {
      "Sid": "DenyIdentityMutationAndRoleChaining",
      "Effect": "Deny",
      "Action": [
        "iam:*",
        "sts:AssumeRole",
        "sts:GetFederationToken",
        "organizations:*"
      ],
      "Resource": "*"
    },
    {
      "Sid": "DenyTamperingWithTheEvidence",
      "Effect": "Deny",
      "Action": [
        "cloudtrail:StopLogging",
        "cloudtrail:DeleteTrail",
        "cloudtrail:UpdateTrail",
        "cloudtrail:PutEventSelectors",
        "guardduty:*",
        "config:Delete*",
        "logs:DeleteLogGroup",
        "logs:DeleteLogStream",
        "logs:PutRetentionPolicy"
      ],
      "Resource": "*"
    },
    {
      "Sid": "DenyEverythingOutsideApSouth1",
      "Effect": "Deny",
      "NotAction": [
        "iam:*",
        "sts:*",
        "kms:DescribeKey"
      ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": "ap-south-1"
        }
      }
    },
    {
      "Sid": "DenyUseOfThisCredentialOutsideOurVpcEndpoints",
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:SourceVpce": [
            "vpce-0a1b2c3d4e5f60718",
            "vpce-0f9e8d7c6b5a40312"
          ]
        },
        "Bool": {
          "aws:ViaAWSService": "false"
        }
      }
    }
  ]
}
```